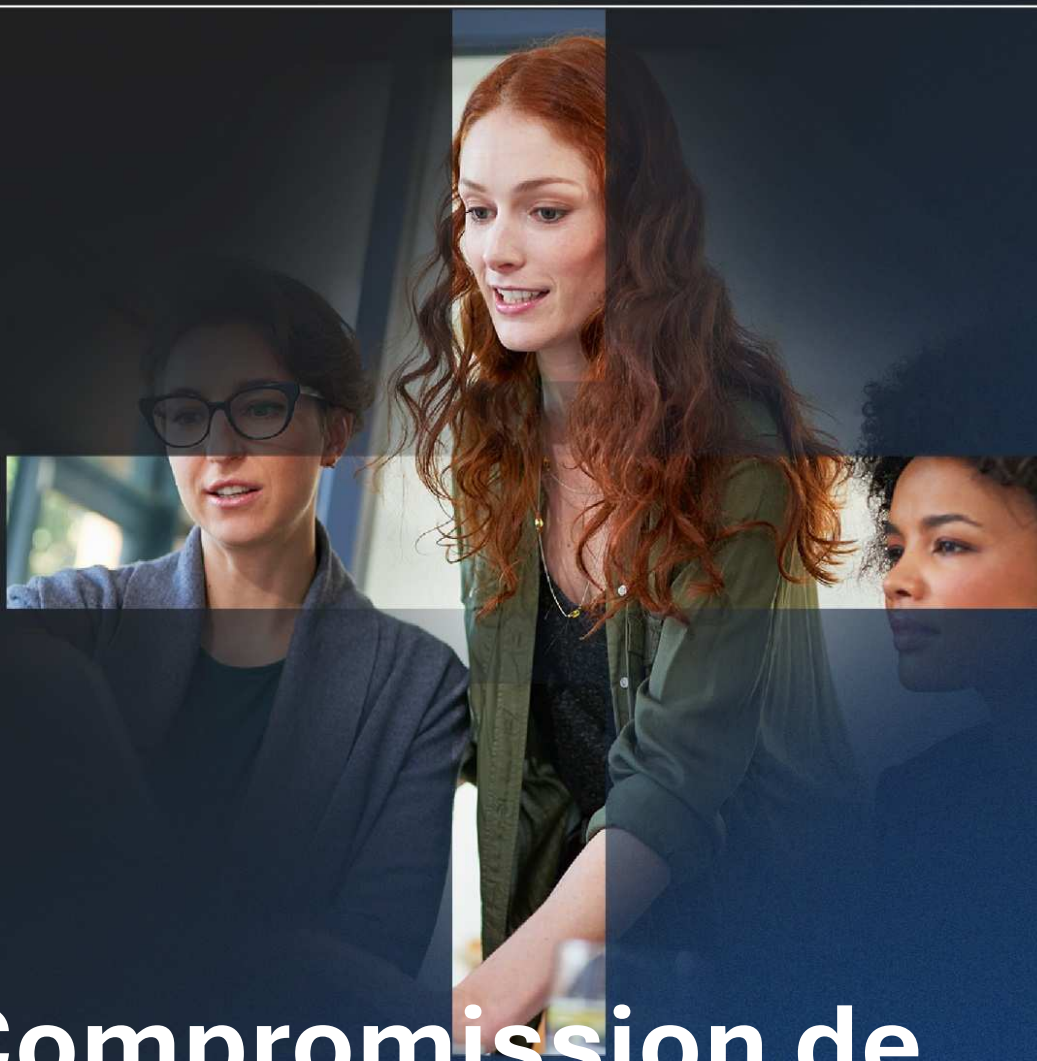




Compromission de messagerie professionnelle

Méthodologie de réponse à incident

SOMMAIRE

Introduction 2

Étapes de traitement des incidents 2

1. Préparation 3

2. Identification 4

3. Confinement 5

4. Remédiation (externe) 6

5. Remédiation (interne) 8

6. Récupération 9

7. Capitalisation et apprentissage 11

INTRODUCTION

Cette méthodologie de réponse à incident est une feuille de route dédiée aux gestionnaires et aux cellules de crise menant une investigation sur un problème de sécurité précis.

→ La fiche IRM s'adresse aux personnes ou fonctions suivantes :

- Les **RSSI et leurs adjoints**
- Le **CERT**
- Le **SOC**
- Les **administrateurs**



Dans le cas d'un incident : Lire l'IRM et prendre des notes.

Rester calme et contacter immédiatement l'équipe de réponse à incident du secteur d'activité ou un CERT si nécessaire.

ÉTAPES DE TRAITEMENT DES INCIDENTS

6 étapes sont définies pour gérer les incidents de sécurité :

1. **Préparation** : Se préparer à gérer l'incident,
2. **Identification** : Détecter l'incident,
3. **Confinement** : Limiter l'impact de l'incident,
4. **Remédiation** : Supprimer la menace,
5. **Récupération** : Revenir à un état normal,
6. **Capitalisation et apprentissage** : Élaborer et améliorer les processus.

Cette IRM fournit des informations détaillées pour chaque étape. Les étapes sont issues du [NIST](#).

Cette fiche est issue du travail collaboratif avec le **CERT-SG** de modification et de mise à jour de leurs fiches de méthodologie de réponse à incident.

Références

- [IRM CERT-SG](#)
- [IRM CERT-aDvens](#)

1. PRÉPARATION

Objectifs : Établir des contacts, définir des procédures et recueillir des informations dans le but de gagner du temps lors d'un incident.

- Élaborer et appliquer des politiques relatives à la sécurité des courriels, les protocoles d'authentification (par exemple SPF, DKIM, DMARC) et les bonnes pratiques d'utilisation des systèmes de messagerie,
- Intégrer les scénarios de compromission de messagerie professionnelle - BEC (Business Email Compromise) dans les plans de réponse à incident, les playbooks et les procédures décrivant les rôles, les responsabilités et les procédures,
- Préparer un plan de communication pour avertir les collaborateurs, les clients et les partenaires qu'une attaque de compromission de messagerie est en cours,
- Établir et tenir à jour une liste de contacts pour demander le retrait de contenus ou domaines auprès des hébergeurs, bureaux d'enregistrement et fournisseurs de messagerie,
- Organiser régulièrement des campagnes de sensibilisation couvrant la compromission de messagerie professionnelle, des incidents liés à l'ingénierie sociale, aux escroqueries et à l'hameçonnage,
- Déployer une solution technique permettant aux collaborateurs de signaler facilement les courriels suspects aux équipes de sécurité ou à un référent local de sécurité,
- Créer des canaux dédiés, tels que des adresses électroniques, des profils de médias sociaux et des lignes téléphoniques permettant aux acteurs externes de signaler les courriels suspects, appels téléphoniques, virements douteux ou tout autre indicateur d'incident lié à une compromission de messagerie,
- Établir des procédures spécifiques pour l'analyse des pièces jointes et des liens URL dans un environnement isolé (sandbox) ou sécurisé, dans le but d'éviter la propagation de l'infection,
- Maintenir une liste des contacts impliqués dans les transactions financières et les virements électroniques, y compris les validateurs,
- Mettre en œuvre des procédures de vérification strictes pour les virements électroniques et les modifications des informations de paiement des fournisseurs,
- Constituer une équipe transverse de réponse à incident ou de gestion de crise, réunissant des représentants de l'informatique, de la sécurité, de la lutte antifraude, de la communication, du service juridique et des unités métiers (à adapter selon le secteur d'activité et les besoins spécifiques de l'organisation).

Surveillance et détection automatisées

- Mettre en place une surveillance automatisée sur l'ensemble des systèmes concernés (serveurs de messagerie, journaux d'accès réseau, systèmes d'authentification) pour détecter en continu les indicateurs de compromission de type BEC,
- S'assurer que tout événement détecté génère immédiatement une alerte à destination de l'équipe de réponse à incident, pour permettre une investigation et des actions rapides,
- Utiliser des outils SIEM (*Security Information and Event Management*) pour corréler les événements et identifier efficacement des schémas BEC potentiels.

DÉFINITION : La compromission de messagerie professionnelle ou BEC (*Business Email Compromise*) est un type d'escroquerie financière avancée dans laquelle les criminels utilisent un accès à une messagerie compromise pour inciter les employés à transférer de grosses sommes d'argent ou des informations sensibles. Les incidents de ce type peuvent entraîner des pertes financières considérables et nuire à la réputation de l'entreprise.

2. IDENTIFICATION

Objectifs : Détecter l'incident, déterminer son ampleur et impliquer les parties concernées.

Identifier les indicateurs de compromission de messagerie professionnelle

- Identifier les courriels demandant des virements, des informations sensibles ou des changements de coordonnées de paiement, en particulier ceux qui ont une tonalité d'urgence,
- Évaluer l'impact potentiel et la gravité de l'incident en fonction de la nature de la compromission,
- Déterminer l'étendue des comptes compromis et l'ampleur de l'attaque,
- Utiliser un système de surveillance centralisé pour toutes ces sources, afin que chaque détection déclenche une alerte immédiate pour une réaction rapide,
- Repérer les courriels qui donnent un sentiment d'urgence, de confidentialité ou des scénarios à fort enjeu, qui pousseraient les destinataires à agir rapidement sans procéder à une vérification approfondie,
- Identifier les écarts de ton, de langage ou de formatage dans les courriels provenant de contacts ou de dirigeants connus,
- Veiller à ce que les alertes soient transmises instantanément à l'équipe de réponse à incident et aux parties prenantes concernées pour permettre une action rapide,
- Évaluer les impacts financiers, de réputations et opérationnels en fonction de la nature et de l'ampleur d'un incident de compromission de messagerie professionnelle,
- Définir des niveaux de gravité en fonction de l'impact potentiel maximal en matière de pertes financières, de compromission des données, d'interruption des opérations, pour prioriser les actions et allouer efficacement les ressources.

Délimiter l'incident

- Identifier l'ensemble des comptes de messagerie compromis et évaluer pour chacun le niveau d'accès détenu au sein de l'organisation,
- Déterminer le mode d'exécution de l'incident de compromission de messagerie : hameçonnage, prise de contrôle de compte ou exploitation de failles dans la logique métier,
- Identifier les départements, services ou unités impactés par l'incident de compromission de messagerie,
- Évaluer si l'attaque provient d'une seule source ou d'un groupe d'acteurs malveillants.

Impliquer les parties concernées

- **Dès la détection d'un incident de compromission de messagerie professionnelle, avertir immédiatement les personnes habilitées à prendre des décisions critiques, notamment la direction générale, les responsables de la sécurité informatique et les responsables financiers,**
- S'assurer que les décisions face aux courriels ou transactions frauduleux soient prises rapidement, idéalement en quelques minutes, pour en limiter les dommages potentiels,
- Mobiliser les services concernés, notamment les services informatiques, juridiques, relations publiques et financiers, pour garantir une réponse coordonnée,
- Si nécessaire, solliciter des partenaires externes tels que les fournisseurs de services de messagerie, des entreprises de cybersécurité ou des autorités compétentes afin de soutenir les opérations d'investigation et de remédiation.

Collecte des preuves

- Collecter des échantillons de courriels frauduleux en préservant intégralement les en-têtes et le contenu pour analyse. Examiner ces échantillons pour identifier des schémas récurrents (adresses IP d'expéditeur, liens malveillants, objets, infrastructure associée),
- S'assurer que les en-têtes des courriels soient intacts pour analyser l'origine, l'acheminement et l'authenticité des messages.

3. CONFINEMENT

Objectifs : Atténuer les impacts de l'incident, empêcher d'autres activités non autorisées et sécuriser les comptes et systèmes compromis pour stopper la progression de l'attaquant.

Isoler les comptes compromis

- Suspendre temporairement ou désactiver les comptes de messagerie identifiés comme compromis pour empêcher tout accès non autorisé et toute activité malveillante,
- Imposer le changement immédiat de mot de passe des comptes compromis et tous les autres comptes partageant des informations d'identification similaires. Vérifier l'intégrité du compte administrateur,
- S'assurer que le MFA soit activé sur l'ensemble des comptes critiques afin d'ajouter un niveau de sécurité supplémentaire,
- Auditer les règles de messagerie récemment créées, qui peuvent contenir des redirections vers des boîtes aux lettres externes, et supprimer toute règle indésirable.

Bloquer les IP et les domaines malveillants

- Identifier et bloquer les adresses IP associées à l'accès non autorisé ou aux activités malveillantes, en utilisant les règles de pare-feu ou de passerelles de sécurité pour le courrier électronique,
- Ajouter à une liste noire les domaines suspects utilisés dans les attaques de phishing ou d'usurpation, pour éviter toute communication future avec ces sources.

Séparer les systèmes affectés

- Isoler les systèmes affectés du réseau principal pour empêcher les attaquants de se déplacer latéralement. Cela comprend la séparation des serveurs de messagerie, des terminaux des utilisateurs et de tous les appareils connectés,
- Mettre en place des contrôles d'accès stricts et veiller à ce que seuls les personnels autorisés puissent accéder aux systèmes critiques durant la phase de confinement.

Restreindre les communications externes

- Restreindre temporairement ou surveiller le trafic de courriel sortant pour détecter et bloquer toute communication frauduleuse,
- Limiter ou suspendre les accès à distance des comptes et systèmes concernés jusqu'à leur sécurisation et leur validation complète.

Vérifier et mettre à jour les politiques de sécurité des courriels

- Améliorer les filtres anti-spam et anti-hameçonnage pour détecter et bloquer plus efficacement les courriels malveillants à partir des indicateurs identifiés lors de la phase d'identification,
- S'assurer que les protocoles d'authentification des courriels tels que SPF, DKIM et DMARC sont correctement implémentés et configurés afin d'empêcher l'usurpation d'adresse mail,
- Mettre en place une surveillance rigoureuse des courriels sortants pour détecter toute information sensible ou tout comportement inhabituel pouvant indiquer des tentatives de compromission en cours,
- Appliquer des restrictions temporaires sur certains types de pièces jointes ou liens hypertextes, jusqu'à ce que la menace soit entièrement contenue et neutralisée.

S'il est rencontré des fraudes de type BEC (compromission de messagerie électronique) plusieurs fois par semaine, il peut être judicieux de mettre en place une alerte ou un bandeau d'avertissement visible à l'échelle de l'organisation. En complément, il peut être envisagé de créer une page d'information décrivant les caractéristiques de cette escroquerie et présentant des stratégies et les bonnes pratiques en matière de prévention.

Gestion de la communication

- Se coordonner avec les équipes chargées des relations publiques et des affaires juridiques, pour préparer des déclarations publiques ou des notifications appropriées aux parties prenantes, aux clients et aux partenaires, tout en contenant des informations sensibles,
- Collaborer avec les forces de l'ordre dès le début de la phase de confinement pour les aider dans leur enquête et suivre leurs instructions.

Préserver les éléments de preuve pour l'enquête

- S'assurer que l'ensemble des journaux pertinents (par exemple, les journaux du serveur de messagerie, les journaux de trafic réseau, les journaux d'authentification) sont conservés dans leur format d'origine à des fins d'analyse et de preuve,
- Créer des images forensiques des systèmes compromis pour permettre une analyse approfondie sans altérer les preuves, ni le matériel d'origine.

Collaborer avec les parties prenantes

- Prendre contact avec les établissements bancaires ou financiers, pour identifier les circuits financiers et permettre d'éventuelles démarches judiciaires,
- Travailler en étroite collaboration avec les équipes informatiques, de sécurité et autres équipes concernées pour mettre en œuvre des mesures de confinement efficaces et veiller à ce que tous les aspects de l'incident soient pris en compte,
- Fournir des mises à jour régulières aux principales parties prenantes sur l'état de confinement et sur tout problème émergent,
- Se coordonner avec les fournisseurs de services de messagerie pour bloquer les courriels malveillants et sécuriser les comptes compromis,
- Communiquer la nature frauduleuse des campagnes de messagerie aux parties externes concernées, telles que les partenaires, les clients ou les institutions financières, etc.

Mettre en œuvre des mesures d'atténuation à court terme

- Réduire temporairement les privilèges des comptes non essentiels à la phase de confinement, pour limiter les risques de compromission supplémentaires,
- Renforcer la surveillance des systèmes et comptes critiques pour détecter toute activité suspecte pendant la phase de confinement.

Mettre à jour les configurations de sécurité

- Appliquer les correctifs et les mises à jour nécessaires sur les systèmes et les logiciels qui ont pu être exploités lors de l'incident compromission de messagerie,
- Adapter la configuration des outils et des systèmes de sécurité pour mieux contrer les tactiques utilisées dans la campagne compromission de messagerie.

4. REMÉDIATION (EXTERNE)

Objectif : Prendre des mesures pour éliminer la menace et éviter de nouveaux incidents.

Si un contenu frauduleux est associé à une escroquerie et est hébergé en ligne :

- **Identifier le propriétaire, l'hébergeur et le registrar (bureau d'enregistrement)** du site frauduleux, avec une documentation complète de l'activité malveillante,
- **Signaler le site frauduleux via les barres d'outils des navigateurs Web pour un blocage instantané.** Mettre en place un blocage à l'échelle de l'entreprise avec des outils de sécurité plutôt qu'uniquement des extensions de navigateur,
- **Rédiger une demande d'abus détaillée** décrivant clairement **la nature de la fraude**, en fournissant des détails et des preuves précises. Inclure des captures d'écran, les en-têtes des courriers électroniques, les adresses IP, les horodatages et les détails des transactions afin de faciliter une réaction rapide de la part du bureau d'enregistrement du domaine ou de l'hébergeur,

- **Envoyer une demande d'abus à l'hébergeur et au bureau d'enregistrement** en utilisant l'adresse électronique *abuse@hostingcompany* ou *abuse@registrar*. Assurer le suivi en utilisant plusieurs canaux de communication, en incluant les équipes de sécurité dédiées lorsqu'elles sont disponibles,
- **Assurer le suivi en contactant directement par téléphone** les équipes chargées des abus et de la sécurité pour accélérer le traitement et obtenir une visibilité sur les délais de résolution,
- **Signaler le compte mail frauduleux à l'hébergeur de messagerie** en demandant officiellement le gel ou la suspension immédiate du compte. Conserver les preuves des courriels conformément à la politique de conservation des données de votre organisation en vue d'éventuelles poursuites judiciaires,
- **Soumettre des dossiers de preuves** comprenant les copies des courriels frauduleux avec les en-têtes complets, l'horodatage des accès non autorisés et la documentation sur l'impact financier,
- **Identifier et documenter toutes les plateformes de médias sociaux utilisées par les attaquants**, y compris les comptes, les publications et les techniques de communication employées,
- **Soumettre des demandes de retrait** à toutes les plateformes de médias sociaux concernées, en indiquant l'adresse de l'équipe de sécurité de votre organisation pour le suivi,
- Bloquer toutes les communications en provenance ou à destination du compte frauduleux pour empêcher toute action malveillante,
- Si aucune réponse ou mesure n'est prise, relancer régulièrement par courriel et par téléphone,
- Si le processus de retrait est lent ou inefficace, contacter une équipe CERT locale du pays concerné. Expliquer les difficultés rencontrées et leur demander assistance pour résoudre le problème et leur fournir les preuves nécessaires.

5. REMÉDIATION (INTERNE)

Objectif : Prendre des mesures afin d'éliminer la menace et d'éviter de nouveaux incidents.

Mettre en œuvre des mesures immédiates de sécurité des comptes ("*quick wins*" / "*gains rapides*").

- Imposer le changement de mots de passe pour tous les comptes concernés et potentiellement concernés,
- Déployer l'authentification multi-facteurs (MFA) pour tous les comptes de courriels professionnels,
- Examiner et révoquer toute règle de redirection de courriel suspecte,
- Désactiver les protocoles mail obsolètes pouvant contourner les mécanismes MFA.

Procéder à une analyse approfondie de l'environnement de messagerie pour améliorer la détection précoce d'incidents de compromission

- Règles de transfert de courrier non autorisées,
- Règles de boîtes de réception suspectes qui déplacent, suppriment ou transfèrent automatiquement les messages,
- Droits d'accès délégués inhabituels,
- Preuves d'exfiltration de courriels ou de téléchargements massifs.

Déployer des solutions de sécurité de courriel avancées avec des fonctionnalités renforcées

- Détection de lieux et d'heures de connexion anormaux,
- Identifier les schémas de redirection suspects,
- Détecter des comportements d'envoi anormaux,
- Mettre en quarantaine des messages contenant des indicateurs de compromission.

Mettre en œuvre des protocoles d'authentification de courriel exigeants

- DMARC (Domain-based Message Authentication, Reporting & Conformance - authentification, rapports et conformité des messages basés sur un domaine),
- SPF (Sender Policy Framework - cadre de politique d'envoi),
- DKIM (DomainKeys Identified Mail - clés de domaine pour l'identification des courriels),
- Configurer, si approprié, des politiques de rejet plutôt que de simple mise en quarantaine pour les messages non-conformes.

Mettre en place des mesures de sécurité financières d'urgence

- Ajouter temporairement des étapes de vérification supplémentaires pour toutes les transactions financières,
- Suspendre toutes les transactions en attente jusqu'à ce que les processus de vérification soient terminés,
- Faire une vérification via un autre moyen de communication, les changements de mode de paiement et de virements bancaires,
- Mettre en place des flux d'approbation basés sur des seuils et nécessitant plusieurs approbateurs.

Déployer des systèmes de surveillance des transactions pour améliorer la détection

- Destinations ou montants de paiement inhabituels,
- Changements dans les informations bancaires des fournisseurs,
- Demandes financières urgentes ou à forte pression,
- Transactions ne correspondant pas aux comportements habituels

6. RÉCUPÉRATION

Objectif : Rétablir le fonctionnement normal des services et systèmes concernés, éliminer les causes de l'incident, renforcer les mesures de sécurité pour prévenir toute récurrence et assurer le rétablissement complet de l'organisation après la compromission.

Analyse des causes

- Analyser en détail les phases d'identification et de confinement pour comprendre comment l'incident de compromission de messagerie s'est produit,
- Déterminer les méthodes et les vecteurs utilisés par les attaquants, tels que les courriels d'hameçonnage, les logiciels malveillants ou les informations d'identification compromises,
- Identifier toute erreur de configuration ou faille de sécurité exploitée lors de l'attaque.

Analyse de l'impact financier

- Évaluer l'impact financier en déterminant l'ampleur des pertes subies,
- Mesurer l'impact des informations sensibles, des transactions financières et l'intégrité opérationnelle,
- Contacter les établissements financiers concernés pour signaler la fraude,
- Demander l'annulation de toute transaction non autorisée si cela s'avère possible,
- Mettre temporairement en mode lecture seule les comptes concernés pour empêcher tout nouvel accès non autorisé.

Éradication des menaces

- Scanner et nettoyer l'ensemble des systèmes affectés afin d'éliminer tout logiciel malveillant, espion ou autre code malicieux introduit durant l'attaque,
- Identifier et supprimer tous les comptes d'utilisateurs ou services non autorisés créés par les attaquants,
- Supprimer les portes dérobées, les scripts ou les processus automatisés installés pouvant maintenir un accès persistant.

Correction des vulnérabilités

- Appliquer les correctifs et mises à jour à tous les logiciels, systèmes d'exploitation et applications, pour corriger les vulnérabilités exploitées,
- Ajuster les paramètres de configuration système selon les bonnes pratiques de sécurité, pour réduire la surface d'attaque.

Renforcer la sécurité du courriel

- Déployer ou mettre à niveau les solutions de sécurité de courriel avec des fonctionnalités avancées telles que le sandboxing (*bac à sable*) ou une analyse heuristique poussée,
- Appliquer le chiffrement des courriels sensibles pour protéger les données en transit,

Pour plus de détails sur l'authentification et la récupération de l'infrastructure, consultez le rapport IRM-18 sur la compromission large périmètre.

Mettre en œuvre des mesures d'authentification avancées

- Étendre le déploiement de l'authentification multifacteur (MFA) à l'ensemble des comptes utilisateurs, en priorité ceux ayant accès aux systèmes critiques,
- Appliquer des politiques de mot de passe robustes, incluant des exigences de complexité et des changements réguliers.

Renforcement de la sécurité du réseau

- Déployer ou mettre à niveau les dispositifs de sécurité adaptés (WAF, IDS, IPS, etc.) pour surveiller et bloquer en temps réel les activités malveillantes,
- Segmenter le réseau plus finement pour limiter l'accès entre unités de l'organisation et réduire la surface d'attaque.

Protection des données et stratégies de sauvegarde

- Veiller à ce que des sauvegardes régulières et sécurisées des données sensibles soient effectuées, puis stockées hors ligne ou dans un environnement cloud sécurisé,
- Mettre en œuvre des solutions DLP (*Data Loss Prevention*) pour surveiller et protéger les données sensibles contre les accès non autorisés ou l'exfiltration.

Restauration à partir de sauvegardes saines

- Restaurer les données et les systèmes à partir de sauvegardes vérifiées comme étant exemptes de compromission, en s'assurant que les données restaurées soient exactes et à jour,
- Confirmer que tous les systèmes restaurés fonctionnent correctement et en toute sécurité, sans malveillance résiduelle.

Retour à un fonctionnement normal

- Tester et valider tous les services et systèmes pour s'assurer qu'ils fonctionnent normalement après restauration,
- Rétablir progressivement l'accès des utilisateurs aux systèmes, en veillant à ce que tous les comptes soient sécurisés et autorisés.

Rapports aux parties prenantes

- Fournir des rapports détaillés aux parties prenantes concernées sur le processus de remédiation et son efficacité,
- Respecter toutes les exigences légales ou réglementaires en matière de déclaration liées à l'incident de compromission de messagerie, en garantissant la transparence et la conformité.

Communication et sensibilisation

- Faire une sensibilisation sur la sécurité, axée sur la prévention des attaques de compromission de messagerie,
- Mettre en œuvre des procédures de vérification complémentaires pour les transactions et les communications financières,
- Établir des protocoles de communication clairement définis pour les futurs incidents de sécurité,
- Effectuer régulièrement des exercices de simulation d'hameçonnage basés sur des scénarios de compromission de messagerie,
- Dispenser une formation spécifique au personnel des services financiers et comptables sur la détection des fraudes.

7. CAPITALISATION ET APPRENTISSAGE

Objectifs : Documenter les détails de l'incident, tirer les leçons et ajuster les mesures de défense.

Rapport

Un rapport de crise doit être rédigé et mis à disposition de l'ensemble des membres de la cellule de gestion de crise.

Les thèmes suivants doivent être décrits :

- Cause initiale de l'infection,
- Actions et chronologie de chaque événement important,
- Ce qui a bien fonctionné,
- Ce qui n'a pas fonctionné,
- Coût de l'incident,
- Indicateurs de compromission (IOC).

Capitalisation

- Identifier les mesures de préparation qui auraient permis de répondre plus rapidement ou plus efficacement à l'incident.
- Mettre à jour les listes de contacts et préciser pour chaque acteur le moyen de communication le plus efficace pour le joindre.
- Recenser les relations internes et externes à l'organisation qui pourraient aider face à de futurs incidents.
- Améliorer les filtres DKIM, SPF et DMARC.
- Collaborer avec les équipes juridiques si une action en justice s'avère nécessaire.